

Incident Report Template

Document Control

Field	Value
Document ID	TMPL-SEC-004-C
Version	1.0
Owner	CISO / IT Security Team
Classification	Internal — Restricted Distribution
Parent Policy	POL-SEC-004 — Incident Response Policy

Instructions: Complete this template for every Medium, High, and Critical incident. Sections marked "Final Report Only" should be completed at incident closure as part of the post-incident review.

1. Incident Summary

Field	Value
Incident ID	[Assigned by SOC/ticketing system]
Date/Time Reported	[YYYY-MM-DD HH:MM, timezone]
Date/Time Detected	[YYYY-MM-DD HH:MM, timezone]
Date/Time Occurred (if known)	[YYYY-MM-DD HH:MM, timezone]
Reported By	[Name/Role/Contact]
Incident Response Manager	[Name]
Current Severity	[Critical / High / Medium / Low]
Initial Severity (if changed)	[Critical / High / Medium / Low]

Status	[Open / Contained / Eradicated / Recovered / Closed]
Sites/Countries Affected	[List]
Systems Affected	[IT / OT / Both — list specific systems]
Personal Data Involved?	[Yes / No / Unknown — if yes, DPO notified: Y/N, date]

2. Description

[Provide a clear, factual narrative of what happened, what was observed, and how it was first identified.]

3. Initial Assessment

Field	Value
Detection Source	[SIEM alert / Employee report / Vendor notification / Third party / Other]
Suspected Cause	[e.g., phishing, malware, misconfiguration, insider, unknown]
Suspected Scope	[Number of systems/users/records potentially affected]
Immediate Risk	[Description of safety, operational, data, or financial risk]
IRT Activated?	[Yes/No — list members activated]

4. Timeline of Actions

Date/Time	Action Taken	Taken By	Notes

(Add rows as needed. This timeline should capture every material action from detection through closure, including containment steps, communications sent, and decisions made.)

5. Containment

Field	Value
Short-Term Containment Actions	[e.g., host isolated, account disabled, network segment blocked]
Evidence Preserved Before Containment?	[Yes/No — describe: forensic image, logs, memory capture, etc.]
Long-Term Containment Actions	[e.g., temporary firewall rule, credential reset]
OT/Production Impact of Containment	[Describe any production/safety impact and Operations sign-off obtained]

6. Eradication

Field	Value
Root Cause	[Confirmed root cause]
Eradication Actions Taken	[e.g., malware removed, vulnerability patched, credentials rotated]
Validation Method	[How eradication was confirmed — scan results, log review, third-party confirmation]
Validation Date	[YYYY-MM-DD]

7. Recovery

Field	Value
Systems Restored	[List systems and restoration method — backup, rebuild, etc.]
Testing Performed Before Return to Production	[Description]

Enhanced Monitoring Period	[Start/end dates and monitoring measures applied]
Date Fully Recovered	[YYYY-MM-DD]

8. Evidence and Chain of Custody

Evidence Item	Collected By	Date/Time Collected	Storage Location	Custody Transfers

9. Communications Log

Stakeholder	Notified By	Date/Time	Method	Content Summary
Executive Management				
Legal Counsel				
Data Protection Officer				
Regulators				
Affected Data Subjects/Customers				
Law Enforcement				
Other				

10. Regulatory Notification Assessment (Final Report Only)

Field	Value
GDPR Personal Data Breach?	[Yes/No, with DPO assessment reference]
Regulator Notification Required?	[Yes/No — if yes, authority, date sent, deadline met Y/N]

Data Subject Notification Required?	[Yes/No — if yes, date sent]
Other Regulatory Obligations Triggered	[List, e.g., industry-specific reporting]

11. Impact Summary (Final Report Only)

Field	Value
Business Impact	[Operational downtime, production impact, financial cost estimate]
Data Impact	[Records/data types affected, confirmed vs. potential]
Reputational/Customer Impact	[Description]
Total Incident Duration	[Detection to closure]

12. Lessons Learned (Final Report Only)

Field	Value
What Worked Well	[Summary]
What Did Not Work Well	[Summary]
Root Cause Summary	[Summary]
Remediation Actions	[Action / Owner / Due Date — table or list]

Remediation Action	Owner	Due Date	Status

13. Sign-Off

Role	Name	Date
Incident Response Manager		

CISO		
Legal Counsel (if applicable)		
Data Protection Officer (if applicable)		

End of Incident Report